CYBERSECURITY AVANZATA · LEZIONI 1-8

Verifica di cybersecurity avanzata

Vulnerabilità e CVE, XSS e CSRF, password e hash, TLS, token e passkey, e-mail, Wireshark, informatica forense. Tempo: 75 minuti. Punteggio totale: 100 punti. Puoi usare la calcolatrice. Mostra sempre i calcoli.

Nome e cognome	Classe	Data

Il caso. Il B&B Il Glicine (inventato) ha un piccolo sito di prenotazione scritto in Java, sul dominio `ilglicine.example`, e ti chiede un controllo di sicurezza. Gli esercizi da 3 a 9 si riferiscono a questo caso.

1. Scelta multipla

18 punti · 3 per domanda

Segna una sola risposta per ogni domanda.

a) Un commento con uno script viene salvato nel database e mostrato a tutti i visitatori. È un XSS…

○ riflesso ○ memorizzato (stored)
○ basato sul DOM ○ CSRF

b) Il salt aggiunto a ogni password serve soprattutto a…

○ rendere la password più lunga per l'utente ○ cifrare la password in modo reversibile
○ dare hash diversi a password uguali e rendere inutili le tabelle precalcolate ○ rallentare il server

c) In TLS il certificato del server serve a…

○ cifrare tutti i dati della pagina ○ dimostrare che il server è davvero quello del dominio
○ nascondere il nome del sito ○ comprimere il traffico

d) Una passkey resiste al phishing perché…

○ è una password molto lunga ○ arriva per SMS
○ la chiave privata è legata al dominio del sito vero e non lo lascia mai ○ cambia ogni 30 secondi

e) Un dominio ha il record DMARC con `p=none; rua=…`. Significa che…

○ le mail false vengono rifiutate ○ le mail false vanno nello spam
○ il dominio riceve i report ma non chiede di bloccare nulla ○ il dominio non invia posta

f) Il filtro di Wireshark che mostra solo i Client Hello di TLS è…

○ `tls.handshake.type == 1` ○ `tcp.port == 80`
○ `dns` ○ `tcp.flags.syn == 1`

2. Vero o falso

12 punti · 1,5 per frase

V ☐ F ☐ Una falla con CVSS 9,8 viene sempre sfruttata prima di una con CVSS 6,1.
V ☐ F ☐ Un hash SHA-256 si può decifrare se si conosce la chiave giusta.
V ☐ F ☐ Con un certificato scaduto il browser mostra un avviso anche se gli algoritmi di cifratura sono robusti.
V ☐ F ☐ Il payload di un JWT firmato con HS256 è cifrato e non si legge senza il segreto.
V ☐ F ☐ Il record SPF elenca i server autorizzati a inviare posta per un dominio.
V ☐ F ☐ Con HTTPS chi gestisce la rete non vede il percorso della pagina, per esempio `/prenota/camera-3`.
V ☐ F ☐ Il gestore del B&B può catturare con Wireshark il traffico degli ospiti sulla sua Wi-Fi, perché la rete è sua.
V ☐ F ☐ Un file copiato su una chiavetta di solito conserva la data di ultima modifica dell'originale.

3. Leggere un avviso di sicurezza

10 punti

Il plugin del calendario usato dal sito ha una falla (avviso inventato) con vettore `CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N`, punteggio 6,1.

a) Spiega in parole semplici `AV:N`, `PR:N` e `UI:R`. *(3 punti)* b) In quale fascia di gravità cade 6,1? *(2 punti)*
c) La falla compare nel catalogo KEV della CISA. Che cosa ti dice e come cambia la priorità rispetto al solo punteggio? *(2 punti)*
d) Hai trovato tu una seconda falla nel plugin, non ancora nota. Scrivi due cose da fare e una da non fare, secondo la divulgazione coordinata. *(3 punti)*

4. XSS e CSRF nel codice

12 punti

Due parti del sito:

```
// 1) pagina di conferma: GET /grazie?nome=...
String nome = parametri.get("nome");
risposta.write("<p>Grazie " + nome + ", prenotazione ricevuta!</p>");

// 2) annullamento: GET /annulla?id=42   (vale il cookie di sessione dell'ospite)
```

a) Che cosa succede se qualcuno fa aprire a un ospite `/grazie?nome=<script>…</script>`? Di che tipo di XSS si tratta? *(3 punti)*
b) Correggi la riga 3: che cosa deve diventare `<b>Anna</b>` prima di essere scritto nella pagina? *(3 punti)*
c) Scrivi l'header Content-Security-Policy che permette solo gli script del sito stesso. *(2 punti)*
d) L'annullamento è vulnerabile a CSRF: spiega l'attacco con un esempio e indica due difese. *(4 punti)*

5. Le password degli ospiti

12 punti

Il sito salva le password come `SHA-256(password)`, senza salt. Un attaccante ruba il database e ha una scheda video che prova **10 miliardi** (10^{10}) di hash SHA-256 al secondo.

a) Quante password diverse di **8 caratteri** si possono fare con lettere maiuscole, minuscole e cifre (62 simboli)? *(2 punti)*
b) Quanto tempo serve, nel caso peggiore, per provarle tutte? Esprimi il risultato in ore. *(3 punti)*
c) Il sito passa a PBKDF2 con **600 000** iterazioni e un salt per utente. Ogni tentativo costa 600 000 hash. Quanto tempo serve ora, in anni? (1 anno ≈ $3{,}16 \times 10^7$ s) *(3 punti)*
d) Due ospiti hanno la stessa password. Che cosa vede l'attaccante nel database senza salt, e che cosa con il salt? *(2 punti)* e) Perché la lunghezza della password conta più dei simboli strani? *(2 punti)*

6. Il token dell'API

10 punti

Dopo il login l'API del sito restituisce un JWT. Le sue tre parti, decodificate da Base64url, sono:

```
{"alg":"HS256","typ":"JWT"} . {"sub":"ospite7","ruolo":"cliente","exp":1893456000} . (firma)
```

a) Che cosa contiene la terza parte e con che cosa la calcola il server? *(2 punti)*
b) Un ospite cambia `"cliente"` in `"gestore"`, ricodifica il payload e rimanda il token con la firma vecchia. Che cosa risponde `GET /api/profilo`, e perché? *(3 punti)*
c) Con il token originale, valido, l'ospite chiama `GET /api/admin`, riservato al ruolo `gestore`. Quale codice HTTP riceve? Spiega la differenza tra 401 e 403. *(3 punti)*
d) Perché conviene una scadenza `exp` breve, per esempio 15 minuti? *(2 punti)*

7. Chi può fingersi il B&B?

8 punti

Dominio	SPF	DMARC in _dmarc.dominio
ilglicine.example	`v=spf1 include:_spf.posta.example ~all`	nessun record
agenzia-viaggi.example	`v=spf1 include:_spf.posta.example -all`	`v=DMARC1; p=reject; rua=mailto:report@agenzia-viaggi.example`

a) Dai a ciascun dominio il giudizio protetto, in osservazione o scoperto, e motiva. *(3 punti)* b) Scrivi in ordine tre consigli per il B&B. *(3 punti)*
c) Un truffatore registra `ilglicine-prenotazioni.example` e configura SPF, DKIM e DMARC perfetti. Perché il DMARC del B&B non può fermarlo? *(2 punti)*

8. Che cosa passa sulla rete

10 punti

Sul tuo PC catturi l'apertura di `https://prenota.ilglicine.example`. Ecco i pacchetti, in disordine:

A · TCP SYN, ACK	B · DNS risposta: 203.0.113.25	C · TLS Client Hello	D · TCP SYN
E · DNS richiesta: prenota.ilglicine.example	F · TLS Server Hello	G · TCP ACK	

a) Scrivi l'ordine corretto delle lettere. *(3 punti)* b) Nel Client Hello, in quale campo leggi il nome del sito? *(1 punto)*
c) Fai un elenco di ciò che vede chi gestisce la rete e di ciò che resta nascosto. *(3 punti)*
d) Il pannello del gestore del B&B, invece, risponde su `http://203.0.113.25:8080/login`. Che cosa vedresti seguendo il flusso HTTP di un login, e come si rimedia? *(3 punti)*

9. Dopo l'incidente

8 punti · 2 per risposta

a) Il PC della reception è acceso e si sospetta un malware. Che cosa raccogli prima, la RAM o il disco? Perché?

b) Sul PC trovi `ospiti.xlsx` con creazione 12/03 alle 21:14 e ultima modifica 05/01. Che cosa è probabilmente successo il 12/03 alle 21:14?

c) Il perito calcola l'hash SHA-256 del disco e della copia: sono uguali. Che cosa dimostra, e che cosa non dimostra?

d) Che cos'è la catena di custodia e perché senza di essa una prova si può contestare?

Punti: _____ / 100 **Voto: _____**